Team: Cyberguardians

PROGETTO THETA

Security Audit & Network Hardening

STRUTTURA DEL TEAM

Luca
Team Leader & Virtualization Specialist
Francesca
Network Architect (Cisco Systems)
Corrado
Security Analyst (Data Decryption)
Ibrahim
Backend Developer

Giorgio
Backend Developer
Domenico
Financial Controller
Veronica
Financial Controller
Batch: *MARZO 2026*

Sommario

1. INTRODUZIONE 3
2. SINTESI 3
3. CONFIGURAZIONE DI RETE 4
4. VIRTUALIZZAZIONE DI RETE 7
5. CONFIGURAZIONE FIREWALL 8
6. VALIDAZIONE E TESTING: SECURITY AUDITING TRAMITE PYTHON 8
7. PREVENTIVO DI SPESA 10
8. CONCLUSIONI 12

1. Introduzione

L’incarico conferito dalla compagnia Theta mira alla progettazione di un’infrastruttura di rete scalabile e sicura per la nuova sede aziendale, strutturata su sei piani per un totale di 120 postazioni. L’obiettivo principale è garantire la massima efficienza operativa e la protezione dei dati societari attraverso una segmentazione rigorosa dei reparti e l'isolamento dei servizi pubblici. A completamento del progetto, viene fornito un preventivo di spesa dettagliato che analizza i costi hardware e software necessari per l’implementazione reale dei sistemi proposti, assicurando un equilibrio ottimale tra prestazioni elevate e sostenibilità economica.

2. Sintesi

L’architettura si basa su una rete gerarchica protetta da un firewall pfSense e suddivisa in subnet dedicate per ogni piano, con l'integrazione di una DMZ per il server web e un sistema NAS per l'archiviazione centralizzata. La validazione del sistema è stata effettuata in ambiente virtualizzato, utilizzando Kali Linux e script personalizzati in Python per testare la robustezza dei servizi e la giusta configurazione del firewall. I test hanno confermato che l'infrastruttura è correttamente configurata, sicura e pronta per supportare i carichi di lavoro previsti.

3. Configurazione di Rete

3.1 Architettura di rete

La struttura è basata su un modello con un centro stella che gestisce il traffico di 6 piani differenti.

- Core: 1 Multilayer Switch (Layer 3).

- Accesso: 6 Switch di piano (Layer 2) collegati in Trunk al Core.

- Utenze: 120 PC distribuiti su 6 VLAN (20 PC per piano).

3.2 Subnetting

Abbiamo segmentato la rete in 6 sottoreti per migliorare la sicurezza e ridurre il traffico di broadcast.

La rete utilizza lo spazio di indirizzamento 192.168.1.0/27. Per massimizzare l'efficienza, ogni piano è stato isolato in una sottorete da 32 indirizzi IP (di cui 30 utilizzabili per i dispositivi).

Piano	VLAN	Sottorete (Network)	Gateway (SVI)	Range IP Host	Subnet Mask
Piano 1	10	192.168.1.0	192.168.1.1	.2 - .30	255.255.255.224
Piano 2	20	192.168.1.32	192.168.1.33	.34 - .62	255.255.255.224
Piano 3	30	192.168.1.64	192.168.1.65	.66 - .94	255.255.255.224
Piano 4	40	192.168.1.96	192.168.1.97	.98 - .126	255.255.255.224
Piano 5	50	192.168.1.128	192.168.1.129	.130 - .158	255.255.255.224
Piano 6	60	192.168.1.160	192.168.1.161	.162 - .190	255.255.255.224

3.3 Configurazione dispositivi di rete LAN

3.3.1 Multilayer Switch

È stata abilitata la funzionalità di routing Layer 3 (Inter-VLAN Routing) sul dispositivo Core, garantendo l'instradamento ad alte prestazioni dei pacchetti tra i diversi domini di broadcast.

- Comandi chiave: IP routing attivato.

- SVI (Switch Virtual Interfaces): Create le interfacce virtuali per ogni VLAN.
- DHCP Server: Configurato direttamente sul Multilayer per assegnare IP e Gateway automaticamente ai PC.

- **Esclusione:** abbiamo escluso gli IP dei Gateway (.1) dai pool per evitare conflitti.
- **Opzione 3:** Configurato il default-router per ogni pool (fondamentale per il ping inter-vlan).

3.3.2 Configurazione degli Switch di Accesso (Piani)

Ogni switch di piano è stato istruito per riconoscere i propri PC.
- Modalità Accesso: Tutte le porte verso i PC (es. fa0/1-20) sono state forzate in switchport access vlan X.
- Modalità Trunk: I collegamenti verso il Multilayer Switch sono stati impostati in trunk per trasportare i tag di tutte le 6 VLAN contemporaneamente.

3.3.3 Implementazione del NAS – VLAN 100 (Storage Dedicated)

Per elevare lo standard di sicurezza e ottimizzare le prestazioni della rete, il NAS è stato isolato in una sottorete dedicata (VLAN 100). Questo impedisce che il traffico pesante di backup interferisca con le attività quotidiane dei dipendenti sui 6 piani e riduce la superficie di attacco in caso di malware nella rete utenti.

- Dettagli logici della Storage VLAN:

- **ID VLAN:** 100 (Nome: NAS)
- **Sottoret**e: 192.168.1.224/27
- **IP NAS:** 192.168.1.230
- **Gateway:** 192.168.1.225
- **Subnet Mask:** 255.225.225.224

- Configurazione Fisica:
Il NAS è collegato fisicamente allo Switch del Piano 1, ma la sua porta è stata configurata logicamente per appartenere alla VLAN 100.

Servizi Attivi:
- FTP: Accesso differenziato per admin (Full Control) e dipendente (Read/Write, no Delete).
- SYSLOG: Repository centrale per la raccolta dei log di sicurezza da Firewall e IDS.
- NTP: Sincronizzazione temporale per garantire la coerenza dei log durante le analisi forensi.

3.4 Configurazione del Firewall Perimetrale (Cisco ASA)

Il Firewall agisce come il "Gatekeeper" tra la rete aziendale interna, la DMZ e il mondo esterno. Abbiamo configurato tre zone con differenti livelli di fiducia.

3.4.1 Segmentazione delle Zone

- “Inside” (Gig1/2): Collegata in Trunk al Multilayer Switch per mantenere la visibilità su ogni singola VLAN (Livello Sicurezza: 100).
- “Outside” (Gig1/1): Interfaccia esposta verso la rete pubblica (Livello Sicurezza: 0).
- “DMZ” (Gig1/3): Zona isolata che ospita il Web Server (Livello Sicurezza: 50).

3.4.2 Routing & NAT

- Server esterno che simula la navigazione web:
- Identità Server: Google Public DND.
- Indirizzo IP: 8.8.8.8
- Subnet Mask: 255.255.255.0
-Gateway del server: 8.8.8.1
- Default Router: Il Firewall è istruito a inoltrare tutto il traffico non destinato alla LAN interna verso l'IP 8.8.8.1, agendo come uscita predefinita per l'intera azienda.
- NAT: È stato implementato il Dynamic PAT. Questo permette ai 120 PC distribuiti sui 6 piani di navigare verso l'IP 8.8.8.8 utilizzando l'unico indirizzo pubblico del Firewall, mascherando gli IP privati della classe 192.168.1.x.
- Policy di ritorno: Per garantire la comunicazione bidirezionale, il Server Internet utilizza il Firewall (8.8.8.1) come gateway per rispondere alle richieste inviate dall'interno.

3.5 Architettura della Zona Demilitarizzata (DMZ)

Per proteggere l'infrastruttura, il Web Server (Metasploitable/DVWA) è stato isolato in una sottorete dedicata, separata dai PC dei piani.

3.5.1 Dettagli logici DMZ

- Rete: 10.0.0.0/24
- IP Web Server: 10.0.0.10
- Gateway (Firewall): 10.0.0.1

3.5.2 Policy di sicurezza (Access Lists)

- Ingresso: Permesso solo il traffico sulla porta TCP 80 (HTTP) dall'esterno verso l'IP del Web Server.
- Uscita: Il Web Server non può avviare connessioni verso la rete Inside (192.168.1.x), prevenendo movimenti laterali in caso di compromissione.

3.6 Implementazione del Sistema di Rilevamento Intrusioni (IDS)

Per garantire una visibilità totale e una difesa in profondità (Defense in Depth), sono stati implementati 3 sensori IDS posizionati nei punti critici dell'infrastruttura. Ogni sensore è configurato tramite Port Mirroring per analizzare il traffico senza degradare le prestazioni di rete.

3.6.1 Sensore 1
- Posizione: Switch d'accesso del Web Server.
- Obiettivo: Rilevare attacchi applicativi (SQL Injection, XSS) diretti verso Metasploitable/DVWA e tentativi di scansione dall'esterno.

3.6.2 Sensore 2:
- Posizione: Switch del Primo Piano.
- Obiettivo: Monitorare l'integrità dei dati aziendali, rilevare accessi non autorizzati al servizio FTP e prevenire tentativi di esfiltrazione dati o ransomware.

3.6.3 Sensore 3:
- Posizione: Switch Multilayer (Centro Stella).
- Obiettivo: Monitoraggio del traffico inter-VLAN. Fondamentale per la visibilità sui movimenti laterali. In caso di rilevamento di scansioni anomale tra i piani, l'IDS invia un alert al sistema di gestione che permette all'amministratore di isolare la porta dello switch compromessa tramite ACL (Access Control Lists).

4. Virtualizzazione di rete

4.1 Configurazione delle schede di rete

4.1.1 Kali Linux
- Scheda 1: Connessa a Rete interna con nome “LAN_ATTACCO”

4.1.2 Metasploitable2
- Scheda 1: Connessa a Rete interna con nome “LAN_TARGET”

4.1.3 pfSense
- Scheda 1: Connessa a NAT
- Scheda 2: Connessa a Rete interna con nome “LAN_ATTACCO”
- Scheda 3: Connessa a Rete interna con nome “LAN_TARGET”

4.2 Configurazione rete delle macchine

4.2.1Kali Linux
La macchina Kali Linux si trova di default sulla rete 192.168.50.0/24.

4.2.2 Metasploitable2
Metasploitable2 si trova di default sulla rete 192.168.50.0/24, per poter simulare al

meglio la rete configurata su Cisco Packet Tracer, modifichiamo l'ip di questa macchina con il comando "sudo nano /etc/network/interfaces" e andiamo ad impostare come ip 10.0.0.10, lo stesso che troviamo assegnato al WEB_SERVER su Cisco.

5. Configurazione firewall

5.1 Interfacce

- WAN: impostate di default.
- LAN: impostiamo la voce IPv4 Configuration Type in "Static IPv4"; IPv4 impostiamo il default gateway "192.168.50.1/24".
- DMZ: impostiamo la voce IPv4 Configuration Type in "Static IPv4"; IPv4 impostiamo il default gateway "10.0.0.1/24".

5.2 Regole

- WAN: impostate di default.
- LAN: 1° regola, Action "Block", Protocol "TCP", Source "LAN subnets", Destination Address "10.0.0.10", Destination Port Range From "SSH (22)" to "3306";
2° regola, Action "Pass", Protocol "TCP", Source "Any", Destination Address "10.0.0.10", Destination Port Range "http (80)".
- DMZ: 1° regola, Action "Block", Protocol "TCP", Source "DMZ subnets", Destination "LAN subnets", Destination Port Range "any".

5.3 Funzionamento delle regole

- WAN: Applica il blocco predefinito di ogni connessione entrante da Internet, proteggendo l'intera rete Theta da scansioni o attacchi esterni non autorizzati.
- LAN: 1° regola, impedisce l'accesso ai servizi critici del server (SSH, MySQL) sulle porte 22-3306, neutralizzando tentativi di controllo remoto o furto di database.
2° regola, abilita esclusivamente il traffico HTTP (80) verso il target, permettendo solo l'analisi controllata del servizio web.
- DMZ: 1° regola, interrompe qualsiasi comunicazione originata dal server verso la rete interna. Serve a sigillare il server nella DMZ: se venisse hackerato, l'attaccante non potrebbe comunque colpire i PC degli uffici.

6. Validazione e Testing: Security Auditing tramite Python

6.1 Obiettivi del testing

- Network Layer: Verificare la raggiungibilità degli host e il blocco del traffico ICMP (Ping).
- Transport Layer: Effettuare il port scanning per confermare le regole di filtraggio TCP.
- Application Layer: Analizzare i metodi HTTP esposti dal Web Server.

6.2 Test 1: Port Scanning

È stato sviluppato uno script in Python per mappare i servizi attivi sul WEB_SERVER. Il test è stato eseguito in due scenari.

6.2.1 Test senza Firewall

In questa fase, lo script Python ha rilevato l'assenza di filtri, evidenziando una configurazione vulnerabile.

- **Porte servizi critici:** La scansione ha trovato aperte le porte 22 (SSH) e 3306 (MySQL). Questo è un grosso rischio perché chiunque potrebbe tentare di indovinare la password per entrare nel server o per rubare i dati dal database.
- **Pericolo Virus e Ransomware:** La porta 445 aperta è un bersaglio facile per i virus che si diffondono nella rete aziendale. Se un PC di un ufficio venisse infettato, il virus potrebbe usare questa porta per colpire anche il server.
- **Conclusione:** Senza firewall, la sicurezza del server dipende solo dalle password. Se una password è debole, l'intera rete della compagnia Theta è in pericolo.

6.2.2 Test con Firewall

Dopo aver attivato le regole su pfSense, abbiamo eseguito di nuovo lo script Python. I risultati mostrano un netto miglioramento della sicurezza.

- **Isolamento dei servizi:** Adesso l'unica porta che risponde è la 80 (HTTP), necessaria per far vedere il sito web.
- **Effetto "Invisibilità":** Lo script ha rilevato un Timeout sulle porte protette grazie al comando dato nel codice (s.settimeout(0.5)). Significa che il firewall non dice nemmeno "porta chiusa", ma ignora completamente i tentativi di connessione non autorizzati. Questo rende molto più difficile per un attaccante capire cosa c'è dentro la rete.
- **Sicurezza dei dati:** Anche se qualcuno trovasse un errore nel sito web (porta 80), il firewall gli impedirebbe comunque di saltare verso le porte del database o del sistema di controllo.
- **Conclusione:** Il firewall ha ridotto la superficie di attacco al minimo indispensabile. Il server è ora protetto da una "bolla" che lascia passare solo i visitatori del sito web e blocca tutto il resto.

6.3 Test 2: Analisi dei Metodi http

Dopo aver identificato la porta 80 (HTTP) come unico varco d'accesso, il team ha effettuato un test di interrogazione degli header per mappare i metodi (verbi) accettati dal WEB_SERVER.

6.3.1 Lo Script di Test

Inizialmente, lo script ha tentato di analizzare la directory principale del database (/phpMyAdmin/).

- Risultato dei test: Il server ha risposto con un codice di redirect (301/302) verso la pagina di login.
- Schermatura lato server: Il redirect ha agito come uno "scudo" iniziale, impedendo allo script di leggere direttamente i metodi HTTP consentiti e nascondendo le informazioni del server.
- Conclusione: Questa configurazione è corretta per proteggere le pagine sensibili, ma non è sufficiente a coprire l'intera superficie del server.

6.3.2 Analisi tramite Risorsa Statica (Bypass)

Il team CyberGuardians ha tentato di enumerare i verbi HTTP. Non riuscendoci ha individuato una risorsa non soggetta a redirect e ha ripetuto il test.
- Risultato dei test: Lo script ha bypassato il blocco e ha ottenuto l'elenco completo dei metodi: GET, POST, OPTIONS, HEAD, TRACE.
- Information disclosure: Il server espone metodi che un utente non dovrebbe vedere, fornendo ad un attaccante informazioni che potrebbero compromettere il sistema.

6.3.3 Conclusioni dell' Audit Applicativo

I test dimostrano che, nonostante la protezione perimetrale del Firewall, il Web Server necessita di un intervento di Hardening
- Disabilitazione metodi pericolosi: È necessario disattivare i verbi a livello di configurazione web server abilitando una whitelist inclusiva dei soli verbi consentiti, evitando quindi superfici di attacco atte allo sfruttamento di eventuali vulnerabilità.

7. Preventivo di spesa

Questa sezione analizza la fattibilità economica dell'infrastruttura per la Compagnia Theta. Trattandosi di un'azienda in crescita, la strategia di budget punta all'equilibrio finanziario. Abbiamo strutturato il preventivo in modo modulare, separando gli investimenti hardware base (CapEx) dai canoni ricorrenti (OpEx), permettendo all'azienda di attivare i servizi opzionali solo se compatibili con il proprio bilancio attuale.

7.1 Sezione interventi strategici

7.1.1 Upgrade tecnologico dell'infrastruttura fisica

- Sostituzione degli apparati della simulazione con dispositivi reali per sostenere i 120 utenti. L'investimento iniziale è calibrato per non risultare proibitivo ma garantire l'efficienza.
- La fornitura delle 120 postazioni di lavoro è stata isolata come voce opzionale per non appesantire il budget dell'infrastruttura di rete centrale.

7.1.2 Sicurezza e Conformità Legale (GDPR)

- Adeguamento Normativo: Progettazione dell'infrastruttura orientata ai principi del GDPR (Regolamento UE 2016/679) per garantire l'integrità e la riservatezza dei dati aziendali.

7.1.3 Ottimizzazione del Budget

- Connettività ottimizzata: Scelta di una fibra ottica FTTH condivisa per abbattere i canoni mensili fissi.

- Meccanismi di Qos (Quality of Service): Configurazione di politiche di priorità del traffico per evitare rallentamenti sui servizi aziendali critici.

- Licenze centralizzate: Utilizzo di software open-source per il monitoraggio interno, aggiornato tramite un'unica sottoscrizione centralizzata per ridurre le spese ricorrenti.

7.2 Sezione Tecnica e Allestimento

Questa sezione del progetto dettaglia la scelta degli apparati fisici e le specifiche tecniche necessarie per l'allestimento degli spazi aziendali e della sala server. La selezione dei materiali rispetta i più alti standard di mercato e le vigenti normative di sicurezza.

7.2.1 Preventivo fornitura materiali

Il presente preventivo definisce la fornitura della componentistica necessaria all'implementazione dell'infrastruttura di rete presso i sei piani della sede Theta. La selezione dei materiali è stata effettuata seguendo rigorosi criteri di sicurezza e qualità, in piena osservanza delle normative vigenti nel settore**.**

7.2.2 Preventivo realizzazione sala server

Il presente preventivo per l'allestimento della sala server è stato redatto con l'obiettivo prioritario di garantire la continuità operativa e la massima protezione degli asset digitali. La proposta segue rigorosamente le normative italiane ed europee in materia di sicurezza degli impianti, prevenzione incendi e protezione dei dati.

7.2.3 Servizi professionali (opzionali)

Al fine di garantire la massima efficienza dell'infrastruttura e la validità delle garanzie sui componenti, la nostra azienda propone il supporto di personale tecnico specializzato per la messa in opera.

8. Conclusioni

Il progetto per l'infrastruttura di rete della Compagnia Theta dimostra come un approccio *Secure-by-Design* possa coniugare alte prestazioni, sicurezza proattiva e sostenibilità economica.

Attraverso la rigorosa segmentazione logica (VLAN), l'isolamento dei servizi esposti (DMZ) e la configurazione avanzata dei firewall (Cisco ASA e pfSense), la superficie di attacco aziendale è stata ridotta al minimo. I test di sicurezza condotti confermano che il perimetro è resiliente contro tentativi di intrusione esterna e *lateral movement* interno, mitigando efficacemente i rischi legati a malware e accessi non autorizzati. L'unica criticità emersa — l'esposizione di metodi HTTP insicuri sul Web Server — richiede un semplice e immediato intervento di *hardening* applicativo.

Infine, la strutturazione modulare del preventivo (distinguendo tra CapEx e OpEx) offre alla direzione aziendale la massima flessibilità finanziaria. L'architettura proposta non solo blinda i dati aziendali in conformità con il GDPR, ma fornisce alla Compagnia Theta una base solida, scalabile e pronta a supportare la crescita futura.

Approvazione del documento

Redatto da: Luca Acunzo **Revisionato da:** Team Cyberguardians	**Approvato da:** Responsabile IT – Compagnia Theta

Storico Revisioni

Versione	Data	Descrizione Modifiche	Autore
1.0	25/03/2026	Bozza iniziale	Admin
1.2 (FINALE)	26/03/2026	Documento completo di Audit Python	Admin

[1]

[1] **Strettamente Confidenziale -**
Questo rapporto è destinato esclusivamente all'uso interno della Compagnia Theta. Contiene dettagli tecnici sensibili che, se divulgati, potrebbero compromettere la sicurezza della rete. Le analisi riflettono lo stato dei sistemi alla data del test.